



ANATOMY OF CVE-2026-9059

Deconstructing the NextGEN Gallery Authenticated SQL Injection

A ROOT-CAUSE TO REMEDIATION BRIEFING

DOCUMENT ID: SEC-BRIEF-2026-9059-R01 | DATE: OCTOBER 26, 2026



9.3 Critical

Core Vulnerability Profile

CVE ID

CVE-2026-9059

Product

NextGEN Gallery (by Awesomemotive)

Vulnerability Type

SQL Injection (CWE-89)

Base Score

9.3 Critical (CVSS v4)

Authentication

Required

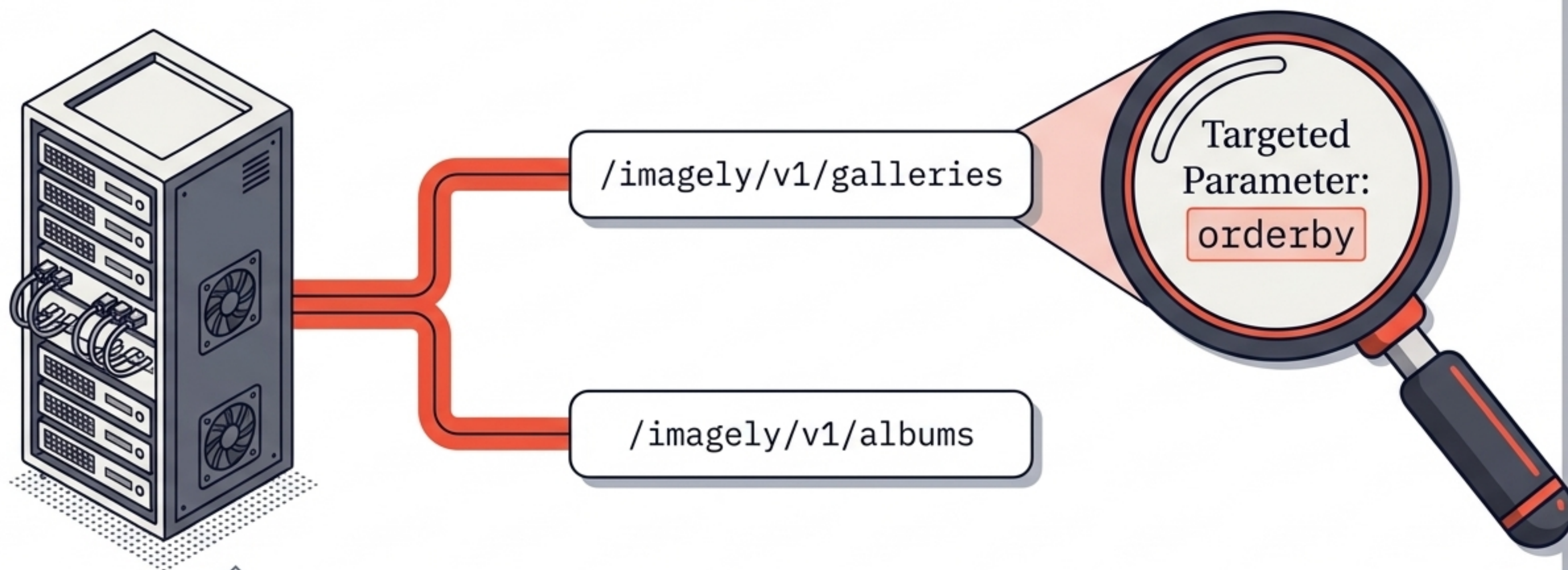
Privilege Level

High (Administrator by default)

Affected Versions

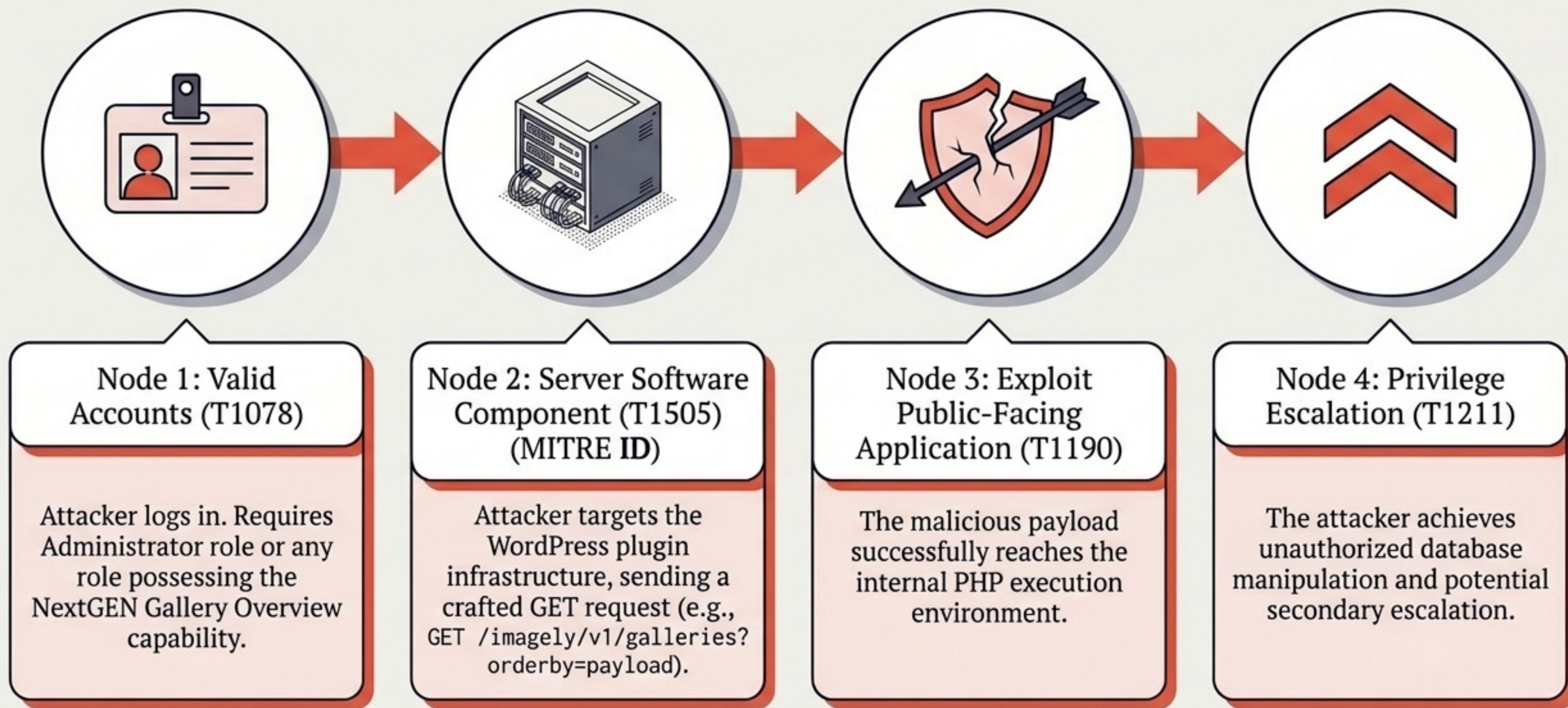
Prior to 4.2.1

Mapping the Exposed Attack Surface



The vulnerability is isolated within specific authenticated REST API endpoints, entirely contingent on the handling of the orderby parameter.

The Adversarial Progression Path



The Danger of the ORDER BY Clause

The Assumption:

Developers frequently assume ORDER BY is harmless because it only sorts existing data.

The Reality:

By manipulating ORDER BY user_input, an attacker changes fundamental SQL execution behavior.

Exploitation Capabilities:

Extract hidden information, modify query logic, enumerate complete database structure, and leak sensitive data.

orderby=payload

Intended Behavior

ID	Gallery Name	Created Date	Access Level
101	Alpha_Gallery	2023-01-15	Public
102	Beta_Gallery	2023-02-10	Private
103	Gamma_Gallery	2023-03-05	Public
104	Delta_Gallery	2023-04-12	Private

Hijacked Behavior

ID	Gallery Name	Created Date	Access
103	Gamma_Gallery	2023-03-05	Public
101	Alpha_Gallery	2023-01-15	Public
104	Delta_Gallery	2023-04-12	Private
102	Beta_Gallery	2023-02-10	Private



Isolating the Root Cause

Point of Failure

Vulnerable Function: `\_clean\_column()` (PHP)

`_clean_column()`



The Flaw

The function relies entirely on Blacklist Filtering. It attempts to remove known bad characters, leaving the system vulnerable to filter evasion and bypass techniques when crafting the final SQL string.

Result

The user-controlled input drops directly into the ORDER BY attacker_input clause without structural validation.

Diagnostic Matrix: Validation Methodologies

Blacklist Filtering (The Flaw)

Mechanism: Attempts to remove 'known bad' characters.

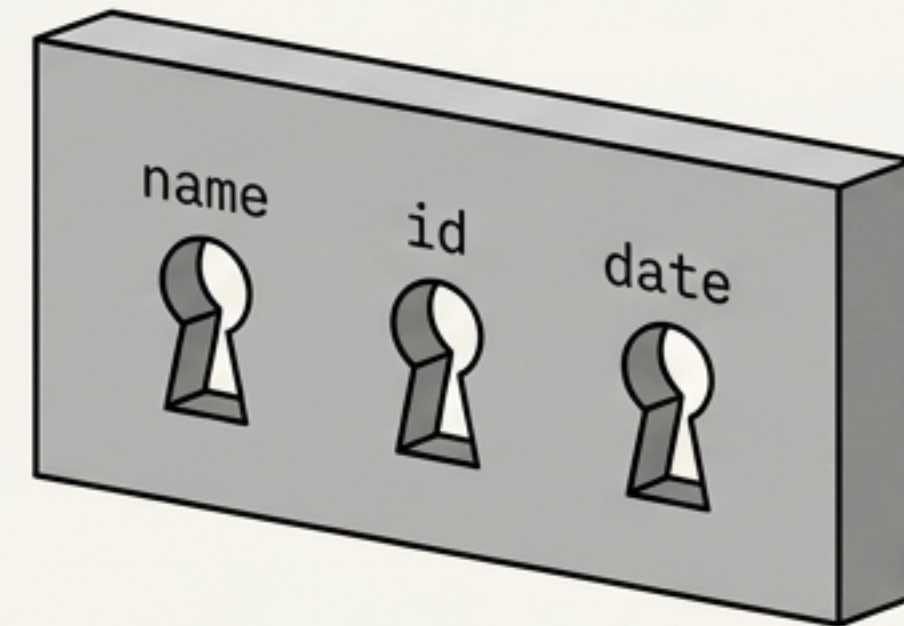
Outcome: Inherently brittle. Attackers continuously discover new bypasses using alternate encodings or unexpected syntax.



Whitelist Validation (The Standard)

Mechanism: Allows strictly predefined, known-safe inputs.

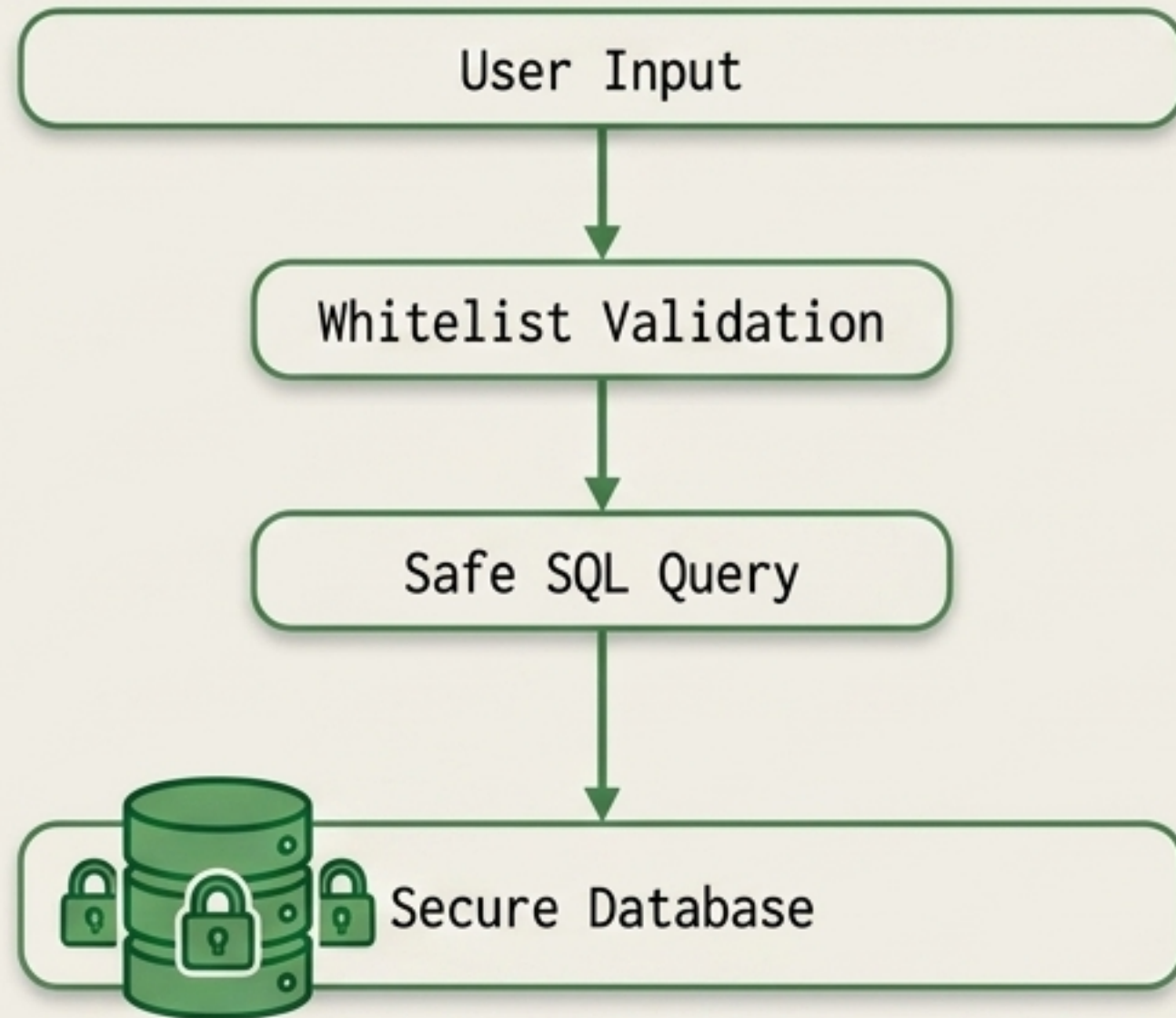
Outcome: Secure by default. Rejects any input not explicitly permitted.



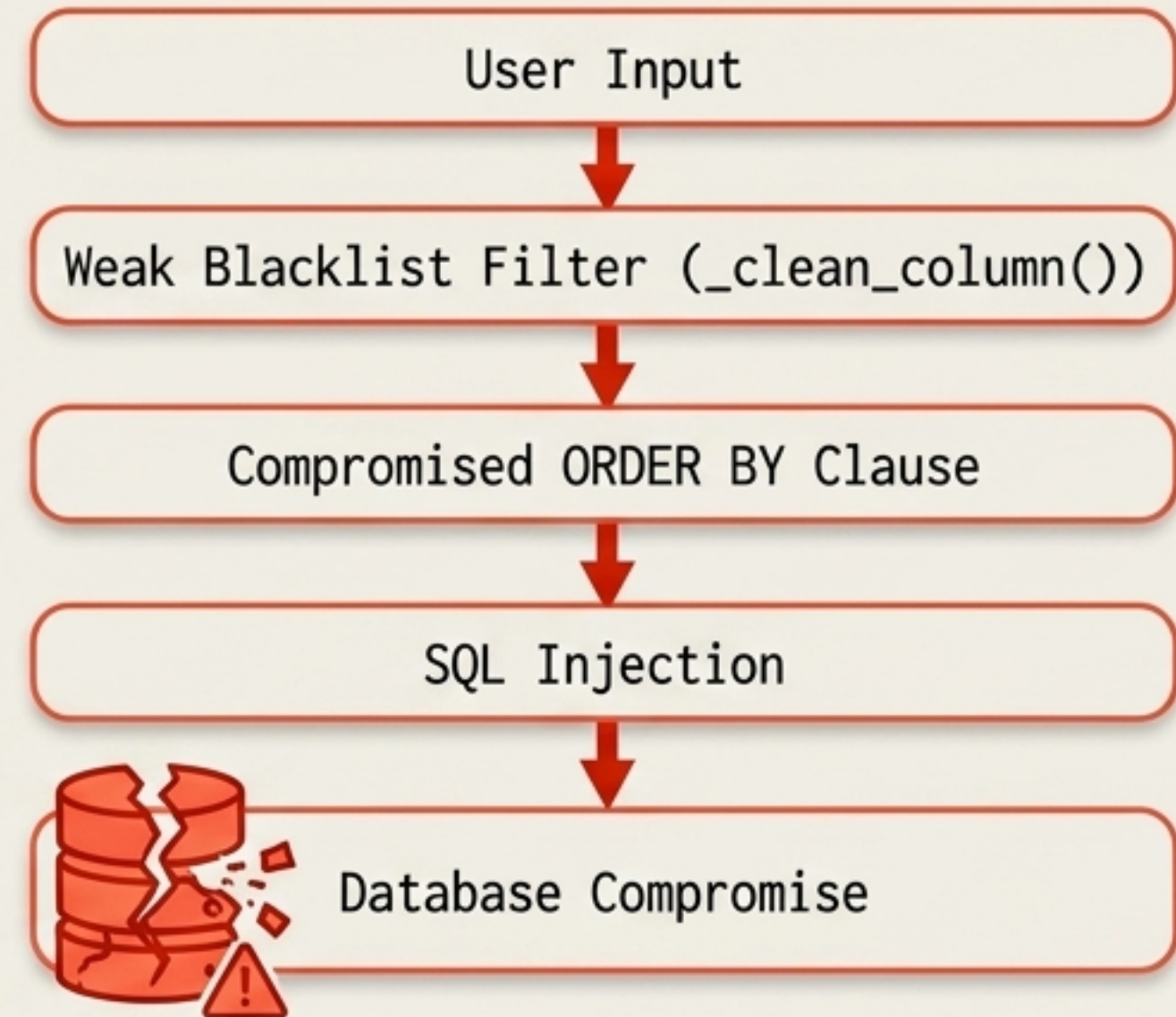
```
$allowed_columns = ['name', 'id', 'date'];
```


Tracing the Data Execution Pathways

Secure Pathway



Vulnerable Pathway



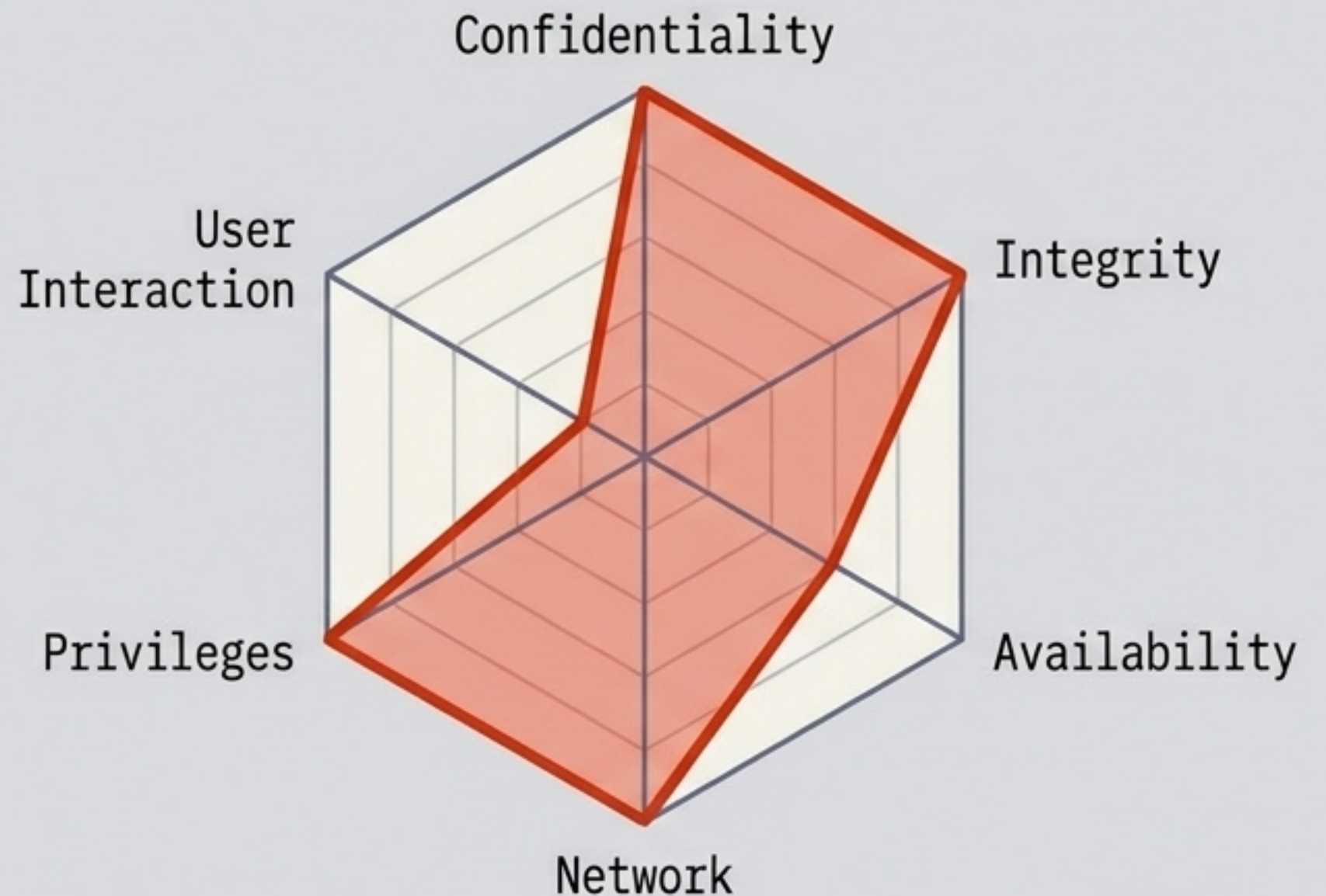
The absence of strict architectural gating allows arbitrary input to bypass the weak filter and physically alter the structure of the resulting database query.

Quantifying the 9.3 Critical Impact

CVSS:4.0/AV:N/AC:L/AT:N/PR:H/UI:N/VC:H/VI:H/VA:N/SC:H/SI:H/SA:H

Key Drivers

- Network-based Attack Vector
- Low Attack Complexity / Zero User Interaction
- High Privileges Required
- Maximum impact on Confidentiality and Integrity



Assessing the Operational Blast Radius

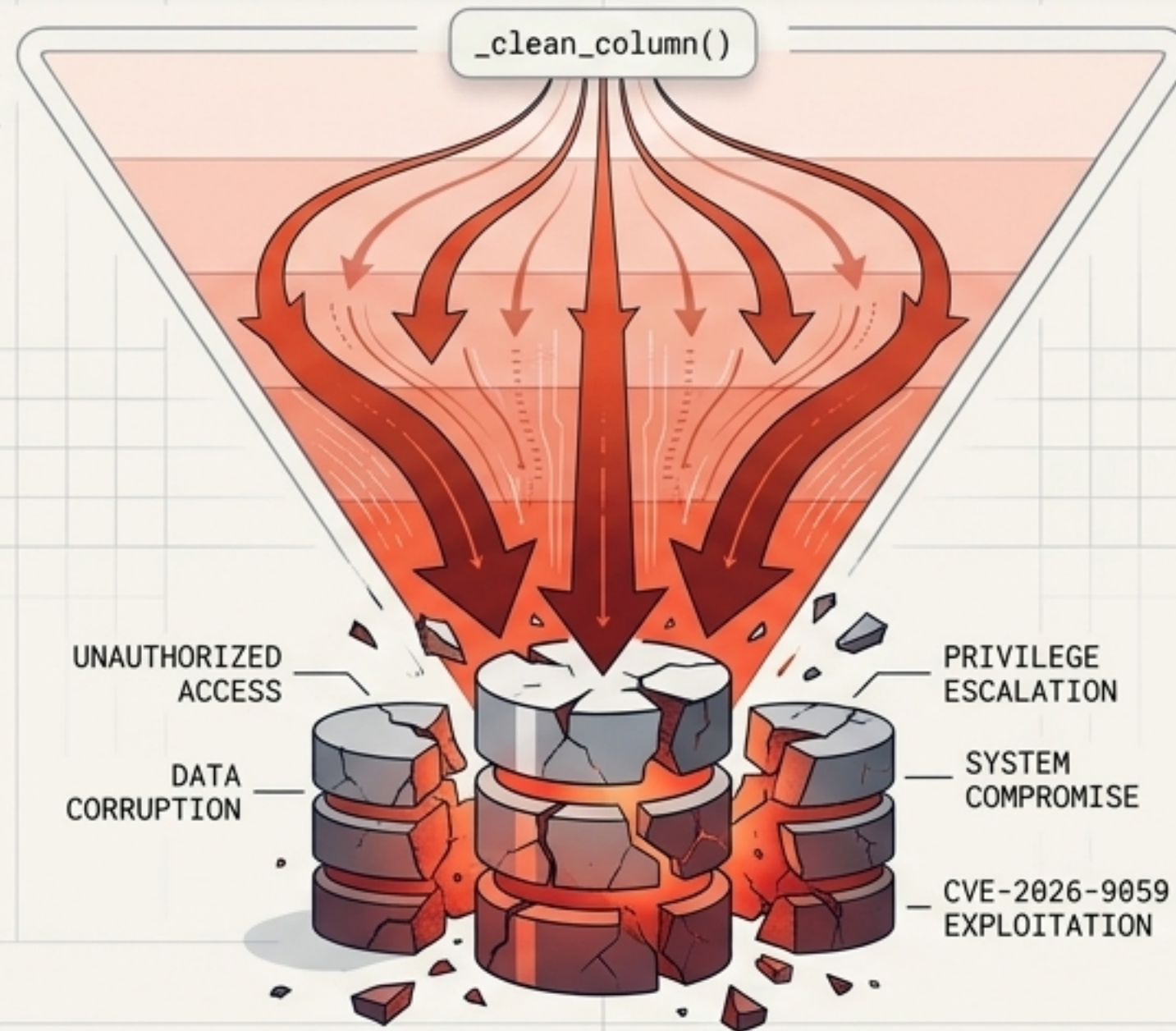


Confidentiality Compromise:
Complete exposure of Gallery Data, User Information, Plugin, underlying Database Records.

Integrity Compromise: Capacity for an adversary to modify change data, and systematically corrupt information.

Availability: No direct DoS impact specified.

The Cascade Effect of Input Validation Failures



A catastrophic **9.3 Critical** severity rating does not require complex memory corruption or cryptographic failures. In CVE-2026-9059, the entire security posture of the WordPress database unravels from a single, localized architectural decision: choosing a blacklist over an array of three permitted words (**name**, **id**, **date**).

Edge Detection: Identifying Active Exploitation

Web Server Logs (Indicators)

[REDACTED]

[REDACTED]

orderby=...

[REDACTED]

[REDACTED]

Monitor traffic for orderby= containing unusual characters, SQL syntax, or excessive length.

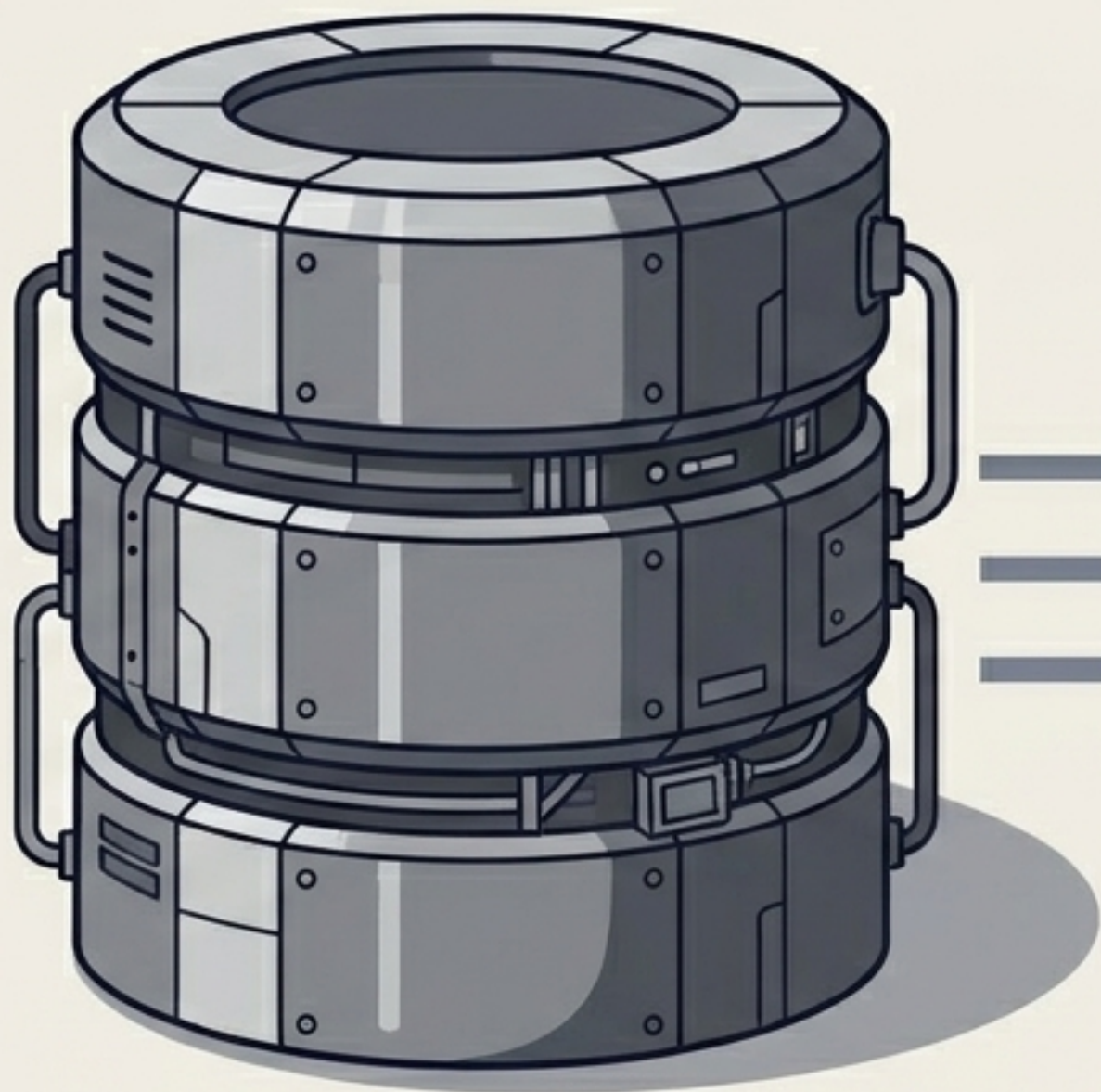
Primary IOC

Repeated, high-volume REST API enumeration requests targeting these specific endpoints.

WAF Rule Triggers

- 🔍 Detect explicit ORDER BY payloads
- 🔍 Flag standalone SQL keywords in parameters
- 🔍 Alert on unexpected API requests to /imagely/v1/*

Core Telemetry: Database Monitoring



Abnormal Queries

Watch for queries structured with unexpected sorting logic.

Database Errors

Alert on SQL syntax errors generated by malformed injection attempts.

Unexpected Query Results

High volumes of data extraction or uncharacteristic record modifications.

Database-level monitoring is critical for identifying successful ORDER BY manipulation that evades perimeter WAF filtering.

Remediation Strategy and Secure Architecture



Immediate Action

Upgrade NextGEN Gallery to Version 4.2.1 or later.

Code-Level Security Improvements



Replace all blacklist logic with strict whitelist validation.



Implement parameterized queries universally.



Enforce rigorous input validation for all API parameters.

Administrative Hardening



Restrict plugin capabilities strictly to required users.



Routinely audit administrator account activity for anomalous behaviors.